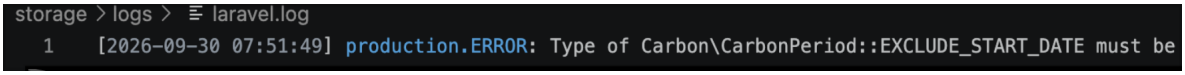
Challenge 3 – Log

Senza log sulle azioni importanti, dopo un DoS è difficile capire chi ha fatto cosa. Il sistema non lascia tracce utili.

Attacco-
Ho controllato storage/logs/laravel.log prima di aggiungere i log di sicurezza. C'erano soprattutto errori tecnici (Carbon, database)e non c'erano tracce chiare di login, cambi ruolo o operazioni sugli articoli. Quindi dopo attacco DoS, dai log non si riusciva a risalire al responsabile





Mitigazione-

Ho aggiunto i log richiesti dalla challenge:
 -Login/logout/registrazione in AppServiceProvider
-Creazione/ modifica/ eliminazione articolo in ArticleController
-Assegnazione ruoli (admin / revisor / writer) in AdminController
In ogni log ho messo informazioni: utente, email dove serve, IP, e id dell'articolo o del ruolo assegnato.

app > Providers > AppServiceProvider.php

```php
<?php

namespace App\Providers;

use Illuminate\Auth\Events\Login;
use Illuminate\Auth\Events\Logout;
use Illuminate\Auth\Events\Registered;
use Illuminate\Cache\RateLimiting\Limit;
use Illuminate\Http\Request;
use Illuminate\Support\Facades\Cache;
use Illuminate\Support\Facades\Event;
use Illuminate\Support\Facades\Log;
use Illuminate\Support\Facades\RateLimiter;
use App\Models\Category;
use App\Models\Tag;
use Illuminate\Support\Facades\Schema;
use Illuminate\Support\Facades\View;
use Illuminate\Support\ServiceProvider;

```

Providers > AppServiceProvider.php

```php
{
    {
        RateLimiter::for('search', function (Request $request) {
            return Limit::perMinute(5)->by($request->ip())->response(function (Request $request
                return response('Too many requests. IP temporarily blocked.', 429);
            });
        });

        RateLimiter::for('global', function (Request $request) {
            return Limit::perMinute(60)->by($request->ip());
        });

        Event::listen(Login::class, function ($event) {
            Log::info('Login', [
                'user_id' => $event->user->id,
                'email' => $event->user->email,
                'ip' => request()->ip(),
            ]);
        });

        Event::listen(Logout::class, function ($event) {
            Log::info('Logout', [
                'user_id' => $event->user?->id,
                'email' => $event->user?->email,
                'ip' => request()->ip(),
            ]);
        });

        Event::listen(Registered::class, function ($event) {
            Log::info('Registrazione', [
                'user_id' => $event->user->id,
                'email' => $event->user->email,
                'ip' => request()->ip(),
            ]);
        });
```

```php
{
    {
        }

        foreach($tags as $tag){
            $newTag = Tag::updateOrCreate([
                'name' => strtolower($tag)
            ]);
            $article->tags()->attach($newTag);
        }

        Log::info('Articolo creato', [
            'article_id' => $article->id,
            'title' => $article->title,
            'user_id' => Auth::id(),
            'ip' => $request->ip(),
        ]);

        return redirect(route('homepage'))->with('message', 'Articolo creato con successo');
```

```php
public function destroy(Article $article)
{
    $articleId = $article->id;

    foreach ($article->tags as $tag) {
        $article->tags()->detach($tag);
    }
    $article->delete();

    Log::info('Articolo eliminato', [
        'article_id' => $articleId,
        'user_id' => Auth::id(),
        'ip' => request()->ip(),
    ]);

    return redirect()->back()->with('message', 'Articolo cancellato con successo');
}
```

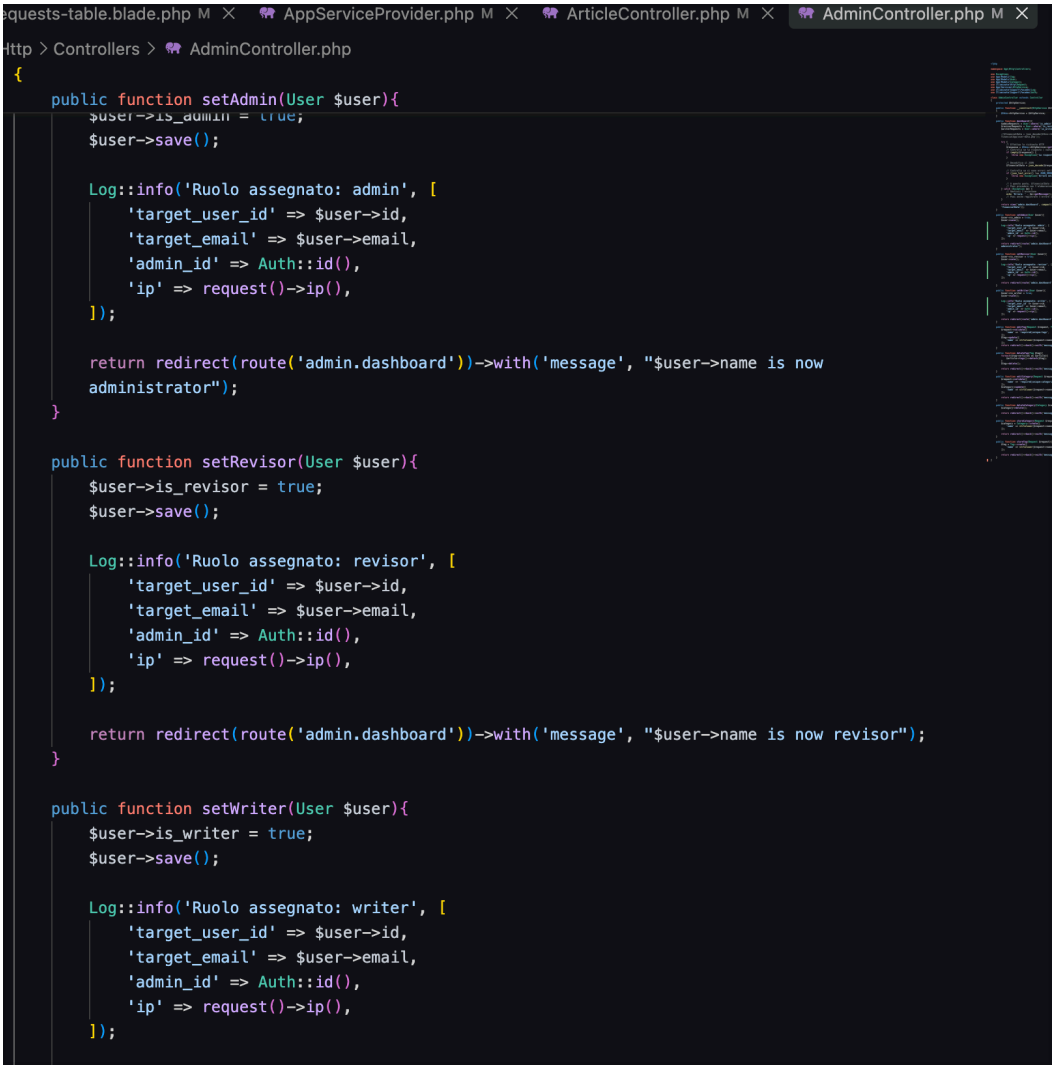
Controllers > ArticleController.php

```php
{

    foreach($tags as $tag){
        $newTag = Tag::updateOrCreate([
            'name' => strtolower($tag)
        ]);
        $newTags[] = $newTag->id;
    }
    $article->tags()->sync($newTags);

    Log::info('Articolo modificato', [
        'article_id' => $article->id,
        'title' => $article->title,
        'user_id' => Auth::id(),
        'ip' => $request->ip(),
    ]);

    return redirect(route('writer.dashboard'))->with('message', 'Articolo modificato con
    successo');
}
```



Dopo mitigazione-

Ho rifatto un login e ho ricontrollato laravel.log. In fondo è comparsa una riga INFO con user_id, email e IP, ad esempio:
local.INFO: Login {"user_id":5,"email":"admin@aulab.it","ip":"127.0.0.1"}
Ora le azioni critiche lasciano traccia: si può risalire a chi ha fatto l'operazione.

